

2.1.7 Practice Questions

Candidate: Abdirahman odorosh (odorosh2)

Date: 11/19/2023 12:20:22 am • **Time Spent:** 03:26

Score: 90%

Passing Score: 80%



▼ Question 1:

✓ Correct

The Chief Information Security Officer (CISO) for a large pharmaceutical corporation receives a report that a hacktivist has vandalized one of the company's web servers due to an authentication flaw at the server level.

As an organizational leader working to prevent future incidents, what should be the CISO's top priority?

- ☐ Analyzing the extent of the damage and restoring the server to its original state.
- ➡ ☒ Reviewing the company's service-level objectives and incident response plan to ensure they are in keeping with industry best practices.
- ☐ Notifying upper management and pre-emptively releasing a statement to prevent damage to the company's reputation.
- ☐ Identifying the attacker's network details and launching a counterattack to prevent further compromise.

Explanation

Service-level objectives (SLOs) provide a benchmark by which security operations can measure their performance and help ensure they meet leadership's expectations. Service-level objectives must be measurable, achievable, and realistic, like any goal-setting initiative. A CISO works at the level of service-level objectives, so reviewing the current SLOs constitutes a suitable answer to prevent future incidents.

Launching a counterattack is neither a legal nor a suitable solution to prevent future incidents.

Notifying upper management is important, but pre-emptively releasing a statement extends beyond the duties of the CISO.

Analyzing the extent of the damage and restoring the server to its original state is important, but these are details that others would handle below the level of the CISO.

References

 2.1.2 Policy and Governance



5.6.8 Key Performance Indicators Facts

q_policy_governance_cisco_top_priority_cdp2.question.fex

▼ Question 2:

✓ Correct

A compliance team keeps a record of the time between issuing and applying a security patch. Who would MOST likely be interested in analyzing this type of information on a regular basis?

- ☐ CIO
- ☐ Governance team
- ☐ Network managers

➡ ☒ Risk managers

Explanation

Compliance teams may review patch management activities and report to risk managers regarding the time between issuing and applying a security patch. Risk managers are most likely to analyze this data to create a trend report identifying that "time to patch" has increased steadily over the last several months.

This information can then be provided to the governance team responsible for crafting a response.

While the CIO and network managers might be interested in this information (especially if it impacts policies), they would not normally analyze the data on a regular basis.

References

2.1.1 Regulations and Standards



2.1.2 Policy and Governance



5.6.1 Vulnerability Management Life Cycle



5.6.2 Vulnerability Management Life Cycle Facts



7.1.4 Create a Remote Access Policy

q_policy_governance_risk_managers_cdp2.question.fex

▼ Question 3: **✓ Correct**

As a security analyst for a U.S. federal agency, you have been asked by management to make sure that the company meets all requirements for FISMA (the Federal Information Security Modernization Act) in a practical and applicable way for your organization.

At the moment, these requirements are not focused on personal data and privacy.

Which of the following resources would MOST likely provide the guidance that you need to meet the FISMA regulations?

- ☐ DNS
- ☐ ISO
- ☐ PCI DSS
- ☒ **NIST**

Explanation

NIST publishes widely adopted and referenced materials in the cybersecurity industry; it does not specifically cover personal data and privacy.

The International Organization for Standardization (ISO) publishes the ISO 27k framework, including 27701, a standard focused on personal data and privacy.

Payment Card Industry Data Security Standard (PCI DSS) is a global data protection standard established and maintained by a consortium of payment card companies. PCI DSS identifies controls designed to prevent fraud and protect credit and debit card data.

Domain Name System (DNS) is a globally distributed service that translates human-readable names (like `www.example.com`) into the numeric IP addresses (like `192.0.2.1`) that computers use to connect to each other.

References

 2.1.3 Industry Standard Publishers Facts

q_standard_publishers_fisma_cdp2.question.fex

▼ Question 4: **✓ Correct**

An IT professional is responsible for ensuring the security of a company's information systems. The professional wants to implement a cybersecurity framework that covers personal data and privacy.

Which of the following industry standard publishers should the IT professional choose?

- ☐ Federal Information Processing Standards (FIPS)
- ☐ Federal Information Security Modernization Act (FISMA)
- ☐ National Institute of Standards and Technology (NIST)
-  ☒ International Organization for Standardization (ISO)

Explanation

The International Organization for Standardization (ISO) publishes the ISO 27k framework, including 27701, a standard focusing on personal data and privacy. Therefore, the IT professional should choose ISO as the industry standard publisher to cover personal data and privacy.

While NIST publishes widely adopted and referenced materials in the cybersecurity industry, it does not specifically cover personal data and privacy.

FIPS are standards published by NIST and referenced in FISMA but do not specifically cover personal data and privacy.

FISMA is a piece of legislation that identifies a requirement to implement the best practice guidance authored by industry-standard publishers such as NIST and ISO, but it does not cover personal data and privacy.

References

 2.1.3 Industry Standard Publishers Facts

q_standard_publishers_iso_scenario_cdp2.question.fex

▼ Question 5:

✓ Correct

A mid-sized company wants to incorporate e-commerce to improve sales. The company has decided to hire an information security consultant to assist in bolstering security measures in preparation for the company's new changes.

The consultant is focusing on the potential risk associated with storing and processing bank information.

What information security standard is the consultant concentrating efforts on?

- ☐ International Organization for Standardization (ISO) 27000 series
- ➡ ☒ Payment Card Industry Data Security Standard (PCI DSS)
- ☐ NIST Cybersecurity Framework (CSF)
- ☐ General Data Protection Regulation (GDPR)

Explanation

Payment Card Industry Data Security Standard (PCI DSS) ensures that companies that handle, process, or store cardholder data do so securely. As a result, the consultant focuses on these standards most when preparing the company for e-commerce standards.

NIST establishes standards and best practices across the entire science and technology field. NIST publishes a wide variety of guidance and best practices within the field of information technology, including cybersecurity.

International Organization for Standardization (ISO) 27000 series develops standards and frameworks governing the use of computers, networks, and telecommunications.

The General Data Protection Regulation (GDPR) rules are stringent and apply no matter where the originating organization operates or where the collected data gets stored, more than just e-commerce and card information.

References

 2.1.4 Regulations and Standards Facts

q_regulation_standards_pci_dss_01_cdp2.question.fex

▼ Question 6: **✓ Correct**

A cybersecurity team at a large financial organization that uses various operating systems, applications, and hardware devices is responsible for configuring these systems securely to prevent potential security breaches.

As part of their research, they came across a set of global data protection standards maintained by a consortium that help prevent fraud and protect transactions for card transactions.

Which of the following standards is designed to meet these protection requirements?

- ☐ CSA STAR
-  ☒ **PCI DSS**
- ☐ CMMI
- ☐ CIS Benchmarks

Explanation

PCI-DSS is a set of requirements for businesses that accept card payments to ensure they securely handle cardholder data. For example, a financial institution must follow PCI-DSS requirements.

CIS Benchmarks are a set of security configuration best practices that provide a secure baseline configuration for various operating systems, applications, and hardware devices.

CSA STAR is a certification program for cloud service providers that demonstrates their compliance with best practices for security and privacy. It does not provide security configuration best practices for operating systems, applications, or hardware devices.

CMMI is a framework for process improvement that helps organizations streamline and optimize their processes to deliver better products and services. It is not related to security configuration best practices.

References

 2.1.4 Regulations and Standards Facts

q_regulation_standards_pci_dss_02_cdp2.question.fex

▼ Question 7: ✕ Incorrect

The solutions architect is in charge of assembling the initial security configuration of various systems on the network, such as Mac, Windows, UNIX, and Linux.

Where would the architect look for configuration guidelines to cover these different systems?

➡ ☒ **Center for Internet Security (CIS) benchmarks**

☐ International Organization for Standardization (ISO) 27000 series

☐ Cloud Security Alliance (CSA)

☐ ~~Open Web Application Security Project (OWASP)~~

Explanation

The Center for Internet Security (CIS) benchmarks provide a secure baseline configuration for various operating systems, applications, and hardware devices. The CIS Benchmark is a broad set of over 100 configuration guidelines covering different aspects of IT security.

Open Web Application Security Project (OWASP) helps developers, testers, and security professionals identify and address security vulnerabilities in web applications.

International Organization for Standardization (ISO) develops many standards and frameworks governing the use of computers, networks, and telecommunications.

Cloud Security Alliance (CSA) refers to best practice documentation on configuring and auditing cloud security.

References

 2.1.5 Center for Internet Security (CIS) Benchmarks

 4.1.3 System Hardening and Configuration Files

 5.6.2 Vulnerability Management Life Cycle Facts

q_cis_benchmarks_cis_01_cdp2.question.fex

▼ Question 8: **✓ Correct**

Which of the following are true statements about CIS Benchmarks? (Select two.)

- ☐ They are accessed through a subscription service.
- ➔ ☒ They are designed to be flexible and scalable.
- ➔ ☒ They can be used to assess the protection of individual systems and configurations.
- ☐ They are designed to be infrequently changed in order to maintain a stable set of guidelines.
- ☐ They include a CIS benchmark implementation tool that can be used for free.

Explanation

The CIS Benchmarks can be used to assess the protection of individual systems and configurations and can be scaled up to evaluate the security of multiple systems and architectures.

The CIS Benchmarks are designed to be flexible and scalable to meet the needs of different organizations.

The CIS Benchmarks are living documents, meaning they are continuously changed and updated by the CIS community based on feedback and new research.

Because the CIS Benchmarks are developed as a collaboration between public and private sector security experts, they are free to download.

Organizations can use a variety of tools to implement the CIS Benchmarks. They can do so by purchasing an on-premises solution or using a cloud-based service, such as the CIS benchmark implementation tool. The implementation tool is a subscription-based service that allows organizations to select and configure a set of CIS Benchmarks based on their industry and organization type.

References

-  2.1.5 Center for Internet Security (CIS) Benchmarks
-  4.1.3 System Hardening and Configuration Files
-  5.6.2 Vulnerability Management Life Cycle Facts

q_cis_benchmarks_true_cdp2.question.fex

▼ Question 9: ✓ Correct

A web developer at a startup company is building a new web application. The developer wants to ensure that the application is secure from various types of attacks.

Which of the following frameworks would be the most appropriate for the web developer to use?

- ☐ Control Objectives for Information and related Technology (COBIT)
- ☐ International Organization for Standardization (ISO) 27001/27002
- ☐ Open Source Security Testing Methodology Manual (OSSTMM)
-  ☒ **Open Web Application Security Project (OWASP)**

Explanation

The Open Web Application Security Project (OWASP) is a comprehensive framework for web application security. It provides guidelines, tools, and resources for web developers to ensure their applications are secure from various types of attacks.

While International Organization for Standardization (ISO) 27001/27002 provides a comprehensive view of information security management, it may not be necessary or appropriate for a web application.

While the Open Source Security Testing Methodology Manual (OSSTMM) provides a systematic approach for security assessments, it may not be necessary or appropriate for a web application.

While Control Objectives for Information and related Technology (COBIT) is a framework for IT governance and management, it does not provide specific guidance for web application security.

References

 2.1.6 Open Web Application Security Project (OWASP)

 5.1.11 Extract Web Server Information

q_owasp_06_cdp2.question.fex

▼ Question 10: **✓ Correct**

An organization has tasked an IT team with implementing vulnerability scanning methods and concepts. They are considering different industry frameworks to use.

Which of the following frameworks focuses on user interaction to prioritize vulnerabilities?

- ☐ FIPS
- ☐ ISO 27001
- ☐ NIST
- ☒ **OWASP**

Explanation

The Open Web Application Security Project (OWASP) is a not-for-profit organization focusing on web application security. It provides free, open-source tools and resources, helping developers and organizations create more secure applications and services, prioritizing vulnerabilities based on their impact on user interaction.

Federal Information Processing Standards (FIPS) are standards published by NIST and referenced in FISMA, but do not specifically focus on user interaction to prioritize vulnerabilities.

The National Institute of Standards and Technology (NIST) is a framework that provides guidelines for cybersecurity, but does not focus specifically on user interaction to prioritize vulnerabilities.

ISO 27001 is an international standard for information security management that provides a framework for identifying and managing vulnerabilities, not user interaction.

References

 2.1.6 Open Web Application Security Project (OWASP)

 5.1.11 Extract Web Server Information

q_owasp_scenario_cdp2.question.fex